UNITÀ 1 · CYBERSECURITY

Simulazione della verifica Unità 1

Stessa struttura e stessa difficoltà della verifica vera, con un caso e domande diversi. Fai la prova in 75 minuti senza appunti, poi correggiti con le soluzioni in fondo.

Nome e cognome	Classe	Data

Il caso. AcquaChiara Servizi (inventata) gestisce l'acqua potabile di 30 comuni, ha 80 dipendenti, un portale per le bollette online e un sistema di telecontrollo degli impianti. Rientra nella NIS2. Gli esercizi da 3 a 9 si riferiscono a questo caso.

1. Scelta multipla

18 punti · 3 per domanda

Segna una sola risposta per ogni domanda.

a) Un DDoS rende irraggiungibile il portale delle bollette per 6 ore. Quale proprietà è violata?

- ○ Riservatezza
- ○ Integrità
- ○ Disponibilità
- ○ Nessuna: nessun dato è stato modificato

b) Un portale di riserva che si attiva entro un'ora riduce soprattutto…

- ○ la probabilità di un attacco
- ○ l'impatto di un fermo
- ○ il numero di attaccanti
- ○ le vulnerabilità del server

c) Nel SOC, il sistema che esegue in automatico i playbook, per esempio isolare un PC o bloccare un IP, è…

- ○ il SIEM
- ○ il SOAR
- ○ l'IDS
- ○ la DMZ

d) Chi raccoglie e conserva le prove di un incidente senza alterarle, documentando la catena di custodia?

- ○ L'analista forense
- ○ Il threat hunter
- ○ Il red team
- ○ L'analista SOC di primo livello

e) Un firewall che guarda ogni pacchetto da solo (IP, porte, protocollo), senza ricordare le connessioni, è…

- ○ un packet filter stateless
- ○ un firewall stateful
- ○ un NGFW
- ○ un WAF

f) Il portale non registra i login falliti, e durante un attacco il SOC non riceve nessun allarme. Categoria OWASP 2021?

- ○ A01 Broken Access Control
- ○ A05 Security Misconfiguration
- ○ A07 Identification and Auth. Failures
- ○ A09 Security Logging and Monitoring Failures

2. Vero o falso

12 punti · 1,5 per frase

- **V** ☐ **F** ☐ Il rischio residuo è quello che resta dopo il trattamento, e la direzione lo deve conoscere e approvare.
- **V** ☐ **F** ☐ Accettare un rischio significa ignorarlo, senza scriverlo da nessuna parte.
- **V** ☐ **F** ☐ Un falso positivo è un allarme che scatta senza che ci sia un attacco.
- **V** ☐ **F** ☐ Il preallarme NIS2 si invia solo se nell'incidente sono coinvolti dati personali.
- **V** ☐ **F** ☐ Con una VPN commerciale nessuno può vedere il tuo traffico, nemmeno il fornitore della VPN.

V ☐ **F** ☐ Nella DMZ si mettono i server che devono essere raggiungibili da Internet.
V ☐ **F** ☐ ROT13 protegge bene un segreto, perché la chiave non viene mai scritta.
V ☐ **F** ☐ In una CTF Jeopardy le sfide sono indipendenti e divise per categoria e punteggio.

3. Il registro dei rischi

12 punti

Probabilità P e impatto I vanno da 1 a 5; R = P × I. Soglie: **Alto** da 15, **Medio** da 8 a 14, **Basso** fino a 7.

Asset · minaccia	P	I	R	Livello
R1 Telecontrollo degli impianti · ransomware	3	5		
R2 Portale bollette · furto delle credenziali dei clienti	4	3		
R3 E-mail dell'ufficio tecnico · phishing	4	4		
R4 Notebook dei tecnici · furto	3	3		
R5 Sito informativo · defacement	3	2		

a) Completa R e livello *(5 punti)*. b) In Calc R è in E2: scrivi la formula per il livello in F2 *(2 punti)*. c) Scrivi il tipo di trattamento (mitigare, trasferire, evitare, accettare) di ogni decisione: cifrare i dischi dei notebook; chiudere il vecchio forum del sito che nessuno usa più; non fare nulla per R5 e scriverlo nel registro *(3 punti)*. d) Per R3 l'azienda organizza una formazione anti-phishing con esercitazioni: abbassa P o I? Perché? *(2 punti)*

4. Gli attaccanti e la kill chain

10 punti

a) Scrivi il profilo dell'attaccante: script kiddie, cybercriminale, hacktivista, gruppo statale (APT), insider. *(4 punti)*

Situazione	Profilo
1. Un ragazzo lancia contro il portale uno strumento scaricato da Internet, "per vedere che succede".	
2. Un impiegato invia per errore l'elenco dei clienti morosi a una mailing list esterna.	
3. Un collettivo sostituisce la home page del sito con slogan contro l'aumento delle tariffe.	
4. Su un forum qualcuno vende l'accesso VPN di un dipendente a chi vuole lanciare un ransomware.	

b) Un attacco ad AcquaChiara, in ordine sparso. Scrivi la fase della Cyber Kill Chain di ogni evento. *(6 punti)*

Evento	Fase
1. Il malware si copia nella cartella di avvio automatico.	
2. L'attaccante cerca sul sito e sui social i nomi dei tecnici e i modelli delle pompe usate.	
3. L'attaccante copia le planimetrie e gli schemi degli impianti.	

4. L'attaccante prepara un PDF "Preventivo pompe" che sfrutta una falla nota del lettore PDF.	
5. Un tecnico apre il PDF con un lettore non aggiornato e la falla viene sfruttata.	
6. Il PDF arriva per e-mail ai tecnici da un indirizzo simile a quello di un fornitore.	

5. MITRE ATT&CK: quale tattica?

6 punti · 1 per riga

Il rapporto del SOC su un'intrusione. Per ogni osservazione scrivi la tattica, scegliendo tra: *Reconnaissance, Initial Access, Execution, Persistence, Privilege Escalation, Credential Access, Discovery, Lateral Movement, Exfiltration, Impact*. Alcune tattiche non servono.

Osservazione	Tattica
1. Dall'esterno qualcuno scansiona le porte aperte del sito pubblico e annota le versioni dei servizi.	
2. Sfrutta una falla non corretta del server VPN esposto su Internet ed entra nella rete.	
3. Lancia sul server uno script PowerShell codificato in Base64.	
4. Elenca gli utenti, i computer e le cartelle condivise della rete.	
5. Estrae le password salvate nel browser di un tecnico.	
6. Copia i dati dei clienti su un server esterno.	

6. Leggere un log

10 punti

Log degli accessi SSH al server del portale, in ordine di tempo. Ogni riga: `ora esito utente ip`. Gli indirizzi 198.51.100.x sono quelli degli uffici di AcquaChiara.

```
06:40:11 OK   tecnico1 198.51.100.30
09:12:30 FAIL abianchi 198.51.100.33
09:12:48 FAIL abianchi 198.51.100.33
09:13:05 FAIL abianchi 198.51.100.33
09:13:40 OK   abianchi 198.51.100.33
14:20:02 FAIL tecnico2 198.51.100.31
14:20:15 OK   tecnico2 198.51.100.31
23:51:00 FAIL root     192.0.2.200
23:51:01 FAIL root     192.0.2.200
23:51:01 FAIL admin    192.0.2.200
23:51:02 FAIL root     192.0.2.200
23:51:02 FAIL oracle   192.0.2.200
23:51:03 FAIL root     192.0.2.200
```

a) Quale IP sta facendo un attacco a forza bruta? Indica due indizi presi dal log. *(3 punti)* b) L'attacco è riuscito? Come lo capisci? *(2 punti)*

c) Applica a mano la regola del mini-SIEM del laboratorio: per ogni IP si contano gli accessi falliti consecutivi; con almeno 3 falliti seguiti da un OK dallo stesso IP scatta un allarme **ALTO**, con almeno 3 falliti e nessun OK un allarme **MEDIO**. Quali allarmi scattano, e per quali IP nessuno? *(3 punti)*

d) Uno dei due allarmi è probabilmente un falso positivo. Quale, perché, e come lo verifichi? *(2 punti)*

7. Risposta all'incidente e NIS2

10 punti

a) Scrivi accanto a ogni azione la fase della risposta: preparazione, identificazione, contenimento, eradicazione, ripristino, lezioni apprese. *(6 punti)*

Azione	Fase
A. Si reinstalla il server da un'immagine pulita, si ricaricano i dati e lo si sorveglia per due settimane.	
B. Si scopre che il server VPN non era aggiornato: si decide di aggiornarlo entro 48 ore da ogni patch critica.	
C. Si blocca sul firewall l'IP esterno e si scollega dalla rete il server compromesso.	
D. Si installa un EDR su tutti i PC e si stila l'elenco dei reperibili, prima di qualsiasi incidente.	
E. Si cancellano lo script e l'account creati dall'attaccante e si applica la patch al server VPN.	
F. L'analista verifica che l'allarme è vero e stabilisce quali server e quali dati sono coinvolti.	

b) AcquaChiara viene a conoscenza dell'incidente significativo **sabato alle 22:30**. A chi va notificato secondo la NIS2? Entro quando vanno inviati preallarme, notifica e relazione finale? *(3 punti)*
c) Nell'incidente non sono coinvolti dati personali. Serve la notifica al Garante? *(1 punto)*

8. Firewall, segmentazione, VPN

8 punti

Segmenti: Internet, DMZ (sito e portale bollette su TCP 443), Uffici, Telecontrollo, Ospiti. Requisiti: da Internet si raggiunge solo la DMZ; gli Uffici non raggiungono il Telecontrollo; nessun servizio interno è esposto su Internet. Le regole si leggono dall'alto: vince la prima che corrisponde, le risposte alle connessioni consentite passano (firewall stateful).

N.	Origine	Destinazione	Servizio	Azione
1	Internet	DMZ	TCP 443	Consenti
2	Internet	Uffici	TCP 3389 (Desktop remoto)	Consenti
3	Uffici	qualsiasi	qualsiasi	Consenti
4	Uffici	Telecontrollo	qualsiasi	Blocca
5	Ospiti	Internet	TCP 80, 443 e DNS	Consenti
6	qualsiasi	qualsiasi	qualsiasi	Blocca

a) Trova i **due errori**, spiega quale requisito violano e correggili. *(4 punti)*

b) Per ogni esigenza scegli la soluzione più adatta tra VPN sito-sito, accesso zero trust alla singola applicazione, segmentazione con VLAN, NGFW. *(4 punti)*

1) Le due sedi di AcquaChiara devono comunicare in modo cifrato attraverso Internet. 2) I tecnici reperibili raggiungono da casa solo l'applicazione del telecontrollo, dopo il controllo di identità e dispositivo. 3) La Wi-Fi ospiti e la rete degli uffici usano gli stessi switch ma devono restare separate. 4) Serve un firewall che riconosca applicazioni e utenti e abbia un IPS integrato.

9. OWASP Top 10: riconosci e correggi

8 punti · 2 per riga

OWASP Top 10 2021: A01 Broken Access Control · A02 Cryptographic Failures · A03 Injection · A04 Insecure Design · A05 Security Misconfiguration · A06 Vulnerable and Outdated Components · A07 Identification and Authentication Failures · A08 Software and Data Integrity Failures · A09 Security Logging and Monitoring Failures · A10 Server-Side Request Forgery

Problema nel portale	Categoria	Correzione
1. Nel campo commenti un utente inserisce uno script, che parte nel browser di chi legge la pagina.		
2. Un utente normale apre `/admin/utenti` e vede l'elenco: il server controlla solo che abbia fatto il login.		
3. Quando qualcosa va storto, il portale mostra all'utente lo stack trace con il testo della query SQL.		
4. Il portale scarica un'immagine da un URL scelto dall'utente; qualcuno gli fa leggere un indirizzo della rete interna.		

10. Capture the Flag ed etica

6 punti

a) Scrivi la categoria CTF di ogni sfida: web, crypto, forensics, reverse, pwn, OSINT. *(4 punti)*
1) Un'immagine PNG nasconde un messaggio nei suoi dati. _____ 2) Un programma in C va in crash se gli dai un nome troppo lungo: devi prenderne il controllo. _____ 3) Devi scoprire in quale città è stata scattata una foto preparata dagli organizzatori. _____ 4) Nel codice HTML della pagina di login della sfida c'è un commento con un percorso nascosto. _____

b) Un amico ti propone di provare i comandi imparati con Bandit sul Wi-Fi del vicino: "tanto guardiamo e basta". Che cosa gli rispondi, e dove può allenarsi legalmente? *(2 punti)*

Punti: _____ / 100 **Voto: _____**

Soluzioni

Correggi la tua prova, somma i punti e dividi per 10: ottieni il voto in decimi. Per ogni errore torna alla lezione su quell'argomento e rifai il laboratorio collegato.

1. Scelta multipla · 3 punti ciascuna

a) **Disponibilità** · b) **l'impatto di un fermo** (non impedisce l'attacco: riduce il danno) · c) **il SOAR** (il SIEM raccoglie e correla, il SOAR agisce) · d) **l'analista forense** · e) **un packet filter stateless** · f) **A09** (senza log il SOC è cieco; A07 riguarderebbe un login debole)

2. Vero o falso · 1,5 punti ciascuna

1 **V** · 2 **F** (si accetta consapevolmente e lo si scrive) · 3 **V** · 4 **F** (la NIS2 riguarda la continuità dei servizi; i dati personali sono il GDPR) · 5 **F** (il fornitore della VPN vede il traffico al posto del provider) · 6 **V** · 7 **F** (è un Cesare con chiave fissa e nota: chiunque lo inverte) · 8 **V**

3. Rischi · 12 punti

a) R1 **15 Alto** · R2 **12 Medio** · R3 **16 Alto** · R4 **9 Medio** · R5 **6 Basso**. b) **=SE(E2>=15;"Alto";SE(E2>=8;"Medio";"Basso"))**. c) Cifrare i dischi: **mitigare** (abbassa l'impatto del furto: il ladro non legge i dati) · chiudere il forum: **evitare** · non fare nulla e scriverlo: **accettare**. d) **Abbassa P**: chi riconosce il phishing clicca meno, quindi l'attacco riesce più di rado; se riesce, il danno è lo stesso.

4. Attaccanti e kill chain · 10 punti

a) 1 **script kiddie** · 2 **insider** (involontario: non è un criminale, ma il danno è reale) · 3 **hacktivista** · 4 **cybercriminale** (è un broker di accessi). b) 1 **installazione** · 2 **ricognizione** · 3 **azioni sull'obiettivo** · 4 **armamento** · 5 **sfruttamento** · 6 **consegna**. Manca il comando e controllo.

5. ATT&CK · 6 punti

1 **Reconnaissance** · 2 **Initial Access** (T1190 Exploit Public-Facing Application) · 3 **Execution** · 4 **Discovery** · 5 **Credential Access** · 6 **Exfiltration**. Non servono Persistence, Privilege Escalation, Lateral Movement, Impact.

6. Log · 10 punti

a) **192.0.2.200**: sei falliti in 3 secondi (ritmo da programma), nomi utente generici (root, admin, oracle), alle 23:51, da un IP che non è degli uffici. b) **No**: dopo i tentativi da quell'IP non c'è nessun OK. c) **ALTO per 198.51.100.33** (3 falliti, poi accesso come abianchi), **MEDIO per 192.0.2.200** (6 falliti); nessun allarme per 198.51.100.30 e 198.51.100.31 (al massimo un fallito). d) **L'ALTO di abianchi**: tentativi a ritmo umano (circa 18 secondi), in orario di lavoro, da un IP degli uffici, sempre lo stesso utente: probabilmente ha sbagliato la password. Si verifica chiedendo direttamente ad abianchi, con un canale noto, se era lui. Contromisure contro il vero attacco: niente login di root via SSH, accesso con chiavi invece della password, blocco temporaneo degli IP dopo N tentativi.

7. Risposta e NIS2 · 10 punti

a) A **ripristino** · B **lezioni apprese** · C **contenimento** · D **preparazione** · E **eradicazione** · F **identificazione**. b) Al **CSIRT Italia** (ACN): **preallarme entro domenica alle 22:30**, **notifica entro martedì alle 22:30**, **relazione finale entro un mese** dalla notifica. c) **No**: senza dati personali non c'è la notifica GDPR al Garante, ma quella NIS2 resta obbligatoria.

8. Rete · 8 punti

a) **Regola 2**: espone il Desktop remoto degli Uffici su Internet; va tolta e sostituita con una VPN con MFA. **Regole 3 e 4**: la 3 consente tutto agli Uffici e viene letta prima, quindi la 4 non si applica mai e gli Uffici raggiungono il Telecontrollo; va spostata la 4 sopra la 3 (o la 3 ristretta a Uffici → Internet e DMZ). b) 1 **VPN sito-sito** · 2 **accesso zero trust** · 3 **segmentazione con VLAN** · 4 **NGFW**.

9. OWASP · 8 punti

1 **A03 Injection** (XSS): codificare l'output prima di inserirlo nella pagina, Content-Security-Policy, cookie di sessione HttpOnly · 2 **A01 Broken Access Control**: controllare sul server il ruolo dell'utente a ogni richiesta, negare per default · 3 **A05 Security Misconfiguration**: messaggi d'errore generici all'utente, dettagli solo nei log interni · 4 **A10 Server-Side Request Forgery**: elenco di destinazioni consentite, bloccare gli indirizzi interni.

10. CTF ed etica · 6 punti

a) 1 **forensics** (steganografia) · 2 **pwn** · 3 **OSINT** · 4 **web**. b) **No**: entrare senza autorizzazione in una rete altrui è accesso abusivo (art. 615-ter c.p.) anche se si "guarda e basta". Ci si allena su bersagli fatti apposta: OverTheWire Bandit, picoGym, Juice Shop sul proprio PC, le CTF e CyberChallenge.IT.